COMPTIA SECURITY+ SY0-701 | DOMAIN 3 · SECURITY ARCHITECTURE (18%)

Security+ 3.1 · Other Infrastructure Concepts

Mestre CyberSec · **Lesson 3.1 — Other Infrastructure Concepts** (14:24) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

> **Executive Lesson Summary:** VM (hypervisor virtualiza o hardware — isolamento forte); container (Docker — roda na kernel do host, leve, isolamento mais fraco por default); ICS/OT (Sistemas industriais: PLC controla a fábrica; SCADA monitora; MUITO patch-hard — ar gap, USB é o vetor, protocolos Modbus/DNP3).

💡 Key Exam Highlights & Critical Concepts

- VM: isolamento STRONG (hypervisor). Container: mais leve, compartilha kernel
- ICS/OT (fábrica, usina): patch MUITO difícil — air gap, DMZ industrial
- IoT/devices: superfície GIGANTE e PATCH-fraco

🎯 Exam Tips & Typical CompTIA Scenarios

- 'isolated with strong boundary' = VM; 'shares kernel with host' = container
- 'sistema industrial isolado com protocolo especial' = ICS/OT

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 3.1 — Other Infrastructure Concepts)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Virtual Machine (VM)

A complete guest operating system running on abstracted hardware provided by a hypervisor, with strong isolation between the host and other VMs. Each VM has its own OS, kernel, memory and virtualized CPU/storage.

⚠️ ***Exam Trap:*** *Cenário com 'strong isolation / strong boundary between environments' = resposta VM/hypervisor. Se a questão fala em consolidar servidores ou isolar apps inseguras com limite forte de separação, pense VM — não container.*

• Hypervisor (Type 1 / Type 2) (VMM)

The Virtual Machine Monitor software layer that manages hardware abstraction and allocates resources to VMs. Type 1 (bare-metal) runs directly on hardware (VMware ESXi, Hyper-V); Type 2 runs on top of a host OS (VirtualBox, VMware Workstation).

⚠️ ***Exam Trap:*** *Type 1 = datacenter/data center, maior performance e segurança; Type 2 = desktop/laboratório. Também lembre: VM escaping (fuga de VM) é o risco de invasor pular da VM para o host — citar isso indica questão sobre risco de virtualização.*

• Container

A lightweight virtualization method (e.g., Docker) where applications package their code and dependencies but SHARE the host OS kernel instead of running a full guest OS. Faster to deploy and more efficient, but with weaker isolation than VMs by default.

⚠️ ***Exam Trap:*** *Gatilho: 'shares the host kernel', 'lightweight/fast deployment', 'packages application with dependencies' = Container. Se a pergunta pedir isolamento MAIS forte entre aplicações, a resposta é VM — container compartilha kernel e isolamento é mais fraco.*

• Industrial Control Systems / Operational Technology (ICS/OT)

Hardware and software that monitor and control physical industrial processes (factories, power plants, water treatment). OT prioritizes availability and safety over patching — systems run for decades and cannot be easily restarted or updated.

⚠️ ***Exam Trap:*** *Cenário com 'sistema industrial, usina, fábrica, não pode receber patch por uptime' = ICS/OT. Defesas corretas: air gap, DMZ industrial, segmentação — NUNCA 'aplicar patch imediato' ou 'conectar à internet'.*

• Supervisory Control and Data Acquisition (SCADA)

A type of ICS that provides centralized, large-scale supervisory monitoring and control of distributed industrial equipment (e.g., pipelines, power grids), typically collecting data from and sending commands to PLCs/RTUs.

⚠️ ***Exam Trap:*** *SCADA = supervisão/monitoramento em larga escala e distribuído; PLC = controle local e direto do equipamento. Lembre do Stuxnet como exemplo clássico de ataque a SCADA/ICS via USB em rede com air gap.*

• Programmable Logic Controller (PLC)

A ruggedized embedded computer that directly controls machinery and physical processes on the factory floor (motors, valves, sensors), executing real-time logic and communicating with SCADA systems.

⚠️ ***Exam Trap:*** *Distinção clássica: PLC 'controla' (age sobre o equipamento), SCADA 'monitora/supervisiona'. Se a questão descreve o dispositivo que liga/desliga a máquina física na fábrica, a resposta é PLC.*

• Air Gap

A physical network isolation strategy where a sensitive network (typically ICS/OT) has NO logical or physical connection to other networks or the internet, protecting against remote attacks.

⚠️ ***Exam Trap:*** *Principal defesa para ICS/OT na prova — mas cuidado: air gap NÃO impede ataque via mídia removível. Questões citando 'USB drive' em ambiente isolado = vetor clássico para furar o air gap (Stuxnet).*

• Modbus / DNP3

Legacy industrial communication protocols used between ICS devices (PLCs, SCADA). Designed for reliability, not security — they lack built-in authentication and encryption, making OT traffic a prime attack target.

⚠️ ***Exam Trap:*** *Gatilho: 'protocolo especial/legado de sistema industrial sem criptografia ou autenticação' = Modbus/DNP3 → ambiente ICS/OT. Compensação correta: segmentação, DMZ industrial e monitoramento — não mexer no protocolo.*

🏛️ Conceptual Deep Dive, Real-World Analogies & GRC Analysis

📌 Software-Defined Networking (SDN): Control Plane vs. Data Plane

🏠 **Real-World Analogy:** Think of a nationwide rail system: The Data Plane is the physical steel tracks and locomotive engines carrying physical freight (the switches and interfaces forwarding packets). The Control Plane is the centralized dispatch tower where traffic controllers monitor screens and program automated track switches. SDN abstracts the brain (Control Plane) away from the muscle (Data Plane) into software.

🔍 **Root Cause & Background:** Configuring hundreds of individual hardware appliances via proprietary CLI scripts created severe configuration drift and human errors. SDN centralizes network policy enforcement and microsegmentation dynamically via programmable controllers.

🛡️ **GRC Auditor Perspective:** Audit privileged access management (RBAC and MFA) guarding the centralized SDN controller; verify mutual TLS encryption on Southbound control channels (e.g., OpenFlow) to block man-in-the-middle route manipulation.

⚠️ **How CompTIA Tests This:** Trigger: 'separates the control plane from the data forwarding plane to allow centralized and programmatic network management'. Answer: Software-Defined Networking (SDN).

📌 SD-WAN (Software-Defined Wide Area Network)

🏠 **Real-World Analogy:** Think of an enterprise navigation app like Waze for shipping fleets: vans can travel via expensive toll turnpikes (private MPLS lines), standard city streets (broadband internet), or ferry crossings (5G cellular). The app continuously benchmarks road congestion and reroutes critical real-time deliveries (VoIP, video calls) over the smoothest pathway automatically.

🔍 **Root Cause & Background:** Rigid legacy MPLS circuits are exorbitant and slow to scale. SD-WAN bonds diverse commodity transports (broadband, fiber, LTE/5G) under an intelligent overlay tunnel, applying cryptographic policies and dynamic path steering based on latency.

🛡️ **GRC Auditor Perspective:** Inspect cryptographic strength on public overlay tunnels (AES-256 GCM); scrutinize branch Direct Internet Access (DIA) and split-tunneling policies to guarantee security inspection (Cloud SWG/SASE) before branch traffic exits.

⚠️ **How CompTIA Tests This:** Trigger: 'dynamic multi-path routing across commodity broadband, MPLS, and cellular connections to optimize branch WAN performance securely'. Answer: SD-WAN.

📌 Microservices and APIs: Decoupled Architectural Interfaces

🏠 **Real-World Analogy:** In a legacy monolith, the entire company sits in one open-plan room: if one person catches a virus, everyone falls sick and business halts. In a Microservices architecture, each function occupies a hermetically sealed, modular booth: one handles payment processing, another runs inventory. They communicate exclusively through standardized intercom pass-throughs governed by APIs.

🔍 **Root Cause & Background:** Monolithic architectures introduce single points of systemic failure and rigid deployment bottlenecks. Microservices deliver fault isolation and horizontal scale, but massively expand internal east-west network exposure, making API gateway governance mandatory.

🛡️ **GRC Auditor Perspective:** Audit API discovery repositories to eradicate zombie and shadow APIs; verify that centralized API Gateways enforce mutual TLS (mTLS), OAuth 2.0 / JWT token validation, and rate limiting against brute-force attacks.

⚠️ **How CompTIA Tests This:** Trigger: 'application architecture broken down into small, modular, independently scalable services communicating over HTTP/REST APIs'. Answer: Microservices.

📌 Container Orchestration: Kubernetes and Cluster Management

🏠 **Real-World Analogy:** If a Docker container is a standardized shipping crate, Kubernetes is the automated harbor crane system and ship captain combined. It tracks every container's weight, automatically replaces damaged containers with exact clones instantly if one is dropped, and balances cargo distribution so the ship never capsizes.

🔍 **Root Cause & Background:** Operating hundreds of micro-containers manually leads to orchestration chaos and downtime. Container orchestration automates health checks, scheduling, and scaling, but exposed Kubernetes API servers or root-privileged containers allow cluster takeover.

🛡️ **GRC Auditor Perspective:** Audit container admission controllers to block root/privileged container execution; enforce Kubernetes NetworkPolicies to prevent unauthorized pod-to-pod east-west lateral movement across namespaces.

⚠️ **How CompTIA Tests This:** Trigger: 'automates the deployment, scaling, health monitoring, and lifecycle management of containerized applications across a cluster of nodes'. Answer: Container Orchestration (Kubernetes).

⚡ QUICK-REFERENCE EXAM CHEAT SHEET

Typical Exam Scenario / Practical Situation	Technical Concept & Target Answer
Architectural separation of network control logic from underlying physical data forwarding hardware	**SDN (Software-Defined Networking)**
Dynamic multi-transport path steering combining broadband, fiber, and LTE connections across enterprise branches	**SD-WAN**
Distributed system composed of modular, independently deployable micro-units communicating via HTTP endpoints	**Microservices and APIs**
Automated engine coordinating lifecycle, auto-healing, and dynamic scaling of container pods across server clusters	**Container Orchestration (Kubernetes)**
Intermediary gateway enforcing authentication, rate-limiting quotas, and security telemetry for programmatic web calls	**API Gateway**
Security risk arising from deprecated, unmonitored, or uninventoried application interfaces left active in production	**Zombie / Shadow APIs**

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A hosting provider must run workloads for multiple customers on the same physical server. The provider wants the strongest practical isolation between tenants and accepts that each tenant may need its own kernel. Which infrastructure approach best meets this requirement?

A) Type 1 hypervisor-based virtual machines

B) Application containers sharing the host kernel

C) Type 2 hypervisor-based virtual machines on a desktop OS

D) Serverless functions in a shared runtime

QUESTION 2 · EXAM SCENARIO

A DevOps team plans to deploy dozens of Docker containers on one Linux host for different internal applications. During review, the security analyst is asked to explain the main isolation limitation compared with virtual machines. Which statement should the analyst provide?

A) Containers share the host operating system kernel, so a kernel exploit may affect the host and other containers.

B) Containers always run with their own Type 1 hypervisor, which prevents kernel attacks.

C) Containers cannot use network namespaces, so they must expose all ports to the host.

D) Containers are isolated by hardware virtualization extensions and do not depend on the host OS.

QUESTION 3 · EXAM SCENARIO

A manufacturing plant has legacy PLCs on an isolated OT network. Because the vendor no longer provides firmware updates, engineers transfer production recipes with USB drives. Management asks for the most effective control to reduce the risk of malware entering the PLC environment through this process.

A) Deploy a dedicated USB scanning kiosk and enforce a removable-media policy with port controls

B) Install endpoint antivirus directly on each PLC

C) Replace Modbus with DNP3 on all PLCs

D) Enable automatic firmware updates from the internet

QUESTION 4 · EXAM SCENARIO

During a plant incident, investigators find that an industrial device is executing ladder logic to directly control a conveyor motor based on sensor inputs. The device receives setpoints from a supervisory system but performs real-time control locally. Which ICS component is described?

A) SCADA server

B) Programmable logic controller (PLC)

C) Historian

D) Human-machine interface (HMI)

QUESTION 5 · EXAM SCENARIO

A water utility has corporate IT and OT networks connected through a shared router. After a ransomware incident on the IT network, the CISO wants to reduce the chance that attacks pivot into SCADA systems. Which architecture change is most appropriate?

A) Implement a segmented OT DMZ with firewall rules that strictly limit IT-to-OT traffic

B) Install a Type 2 hypervisor on each PLC

C) Move all PLCs to the corporate domain for centralized patching

D) Disable SCADA logging to reduce attack surface

QUESTION 6 · EXAM SCENARIO

A malware analyst needs to detonate suspicious samples on a laptop running Windows. The analyst installs virtualization software as an application on the Windows host and creates an isolated guest OS. Which hypervisor type is being used, and what is the primary security implication?

A) Type 1; the hypervisor runs bare metal and provides stronger isolation than containers.

B) Type 2; because it runs on a host OS, a hypervisor or host compromise can affect the guest and host.

C) Type 1; the guest OS shares the host kernel, making escape easier.

D) Type 2; the hypervisor replaces the host OS and prevents all malware from affecting the host.

QUESTION 7 · EXAM SCENARIO

A security team is hardening a Kubernetes environment that runs containers for public web applications. The team wants to reduce the impact of a container escape. Which configuration change is most effective?

A) Run containers as root to simplify file permissions

B) Use privileged containers so they can access host devices

C) Run containers rootless with minimal Linux capabilities and enable seccomp/AppArmor profiles

D) Disable network policies so containers can communicate freely

QUESTION 8 · EXAM SCENARIO

A SOC observes Modbus/TCP traffic from an internet-facing address reaching a programmable logic controller. The PLC controls a physical process. What is the most significant security concern?

A) Modbus uses strong mutual authentication, so the traffic is likely benign.

B) Modbus is designed for trusted networks and typically lacks authentication and encryption, so exposure can allow unauthorized control.

C) Modbus encrypts all commands with TLS, but the certificate may be expired.

D) Modbus only supports monitoring and cannot change PLC outputs.

QUESTION 9 · EXAM SCENARIO

An auditor finds that an organization's OT network is described as air-gapped, but contractors regularly connect laptops to switches for diagnostics. Which recommendation best preserves the intent of an air gap while allowing necessary maintenance?

A) Rely on the air gap because physical access is already restricted.

B) Allow contractor laptops to connect if they have current antivirus.

C) Implement strict controlled access with a mediated jump host, scanning, logging, and removable-media controls for maintenance connections.

D) Connect the OT network to the internet so vendors can patch PLCs remotely.

QUESTION 10 · EXAM SCENARIO

A virtualized data center uses a small number of golden VM templates to deploy new servers. Administrators often create temporary VMs that remain powered on after projects end. Which risk should the security team prioritize?

A) Unpatched or misconfigured dormant VMs and template images may introduce vulnerabilities into new deployments.

B) Type 1 hypervisors cannot enforce isolation between VMs.

C) Containers are required to run templates securely.

D) Air gaps automatically patch VM templates.

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option A — Type 1 hypervisor-based virtual machines

Type 1 hypervisor-based virtual machines provide hardware virtualization with strong isolation because each VM has its own kernel and the hypervisor runs directly on the hardware. Containers share the host kernel, reducing isolation. Type 2 hypervisors depend on a host OS and are less suitable for multitenant production. Serverless shares a runtime and does not provide equivalent isolation.

Question 2: Option A — Containers share the host operating system kernel, so a kernel exploit may affect the host and other containers.

Containers share the host OS kernel and use namespaces and cgroups for isolation. If an attacker exploits a kernel vulnerability or insecure configuration, the host and other containers may be affected. VMs have their own kernels and hardware-enforced isolation, which is generally stronger.

Question 3: Option A — Deploy a dedicated USB scanning kiosk and enforce a removable-media policy with port controls

In OT environments that are patch-hard, removable media is a common attack vector. Blocking unauthorized ports, using scanning kiosks, and enforcing removable-media policy reduce risk without relying on PLC patching. Antivirus on PLCs is usually not viable. Changing protocol does not remove the USB vector. Internet firmware updates increase exposure.

Question 4: Option B — Programmable logic controller (PLC)

A PLC executes real-time control logic and drives actuators such as motors and valves. SCADA supervises and gathers data; an HMI is the operator interface; a historian stores historical data.

Question 5: Option A — Implement a segmented OT DMZ with firewall rules that strictly limit IT-to-OT traffic

Segmentation with an OT DMZ and restrictive firewall rules limits lateral movement between IT and OT. PLCs do not run Type 2 hypervisors. Putting PLCs in the corporate domain increases exposure. Disabling SCADA logging worsens detection and does not solve the pivot.

Question 6: Option B — Type 2; because it runs on a host OS, a hypervisor or host compromise can affect the guest and host.

Virtualization installed as an application on Windows is a Type 2 (hosted) hypervisor. It depends on the host OS; if the host or hypervisor is compromised, isolation can be broken. Type 1 runs bare metal. Containers, not Type 1 VMs, share the kernel.

Question 7: Option C — Run containers rootless with minimal Linux capabilities and enable seccomp/AppArmor profiles

Running rootless, removing unnecessary capabilities, and applying seccomp/AppArmor reduces privileges and attack surface, limiting the impact of a container escape. Root and privileged containers increase risk. Disabling network policies increases lateral movement.

Question 8: Option B — Modbus is designed for trusted networks and typically lacks authentication and encryption, so exposure can allow unauthorized control.

Modbus and DNP3 in their basic forms were designed for trusted networks and lack robust authentication/encryption. Exposing PLCs to the internet can allow unauthorized commands and physical process manipulation. Modbus can write to registers/outputs, not only monitor.

Question 9: Option C — Implement strict controlled access with a mediated jump host, scanning, logging, and removable-media controls for maintenance connections.

An air gap is compromised by temporary connections. The correct approach is to control and mediate any connection with a jump host, scanning, logging, and removable-media policy. Relying only on physical access or antivirus is insufficient. Connecting to the internet violates the air gap and increases risk.

Question 10: Option A — Unpatched or misconfigured dormant VMs and template images may introduce vulnerabilities into new deployments.

VM sprawl and outdated golden images are common virtualization risks. Forgotten VMs may remain unpatched and exposed, and vulnerable templates propagate flaws to new systems. Type 1 hypervisors isolate VMs. Containers are not required for secure templates. Air gaps do not apply patches.